01 - Risk Management Methodology

1. Objective

To define the **methodology** for managing **risks associated** with the **electronic** patient information system by identifying, analyzing, evaluating, and treating risks, then monitoring the implementation of treatment plans and continuously reviewing risks.

This **methodology** aims to support the system's **objectives** of **Confidentiality, Integrity, and Availability (CIA)** and ensure that risk-related decisions are made according to clear criteria and defined responsibilities.

2. Scope

This **methodology applies** to the **electronic patient information system** defined within the project scope, including patient information registration, appointment management, medical record storage and retrieval, and user account and access permission management.

The assessment includes the cloud services hosting the system to the extent that they affect the system's security and the availability and integrity of its information.

This methodology does not cover all other hospital systems or operations.

3. Risk Management Stages

Risk management follows the stages **below**.

3.1 Risk Identification and Information Gathering

Identify potential events that may **affect** the **system** and its **objectives**. **Collect information** about **risk** causes, sources, vulnerabilities, and existing controls.

3.2 Risk Analysis

Analyze each risk in terms of its **likelihood** and potential **impact**, considering the effectiveness of existing controls and the available information.

3.3 Risk Evaluation

Determine each **risk level** using the **analysis results** and the approved **risk assessment matrix**. Compare the results against the risk appetite and risk tolerance documented in the project.

3.4 Risk Treatment

Select an appropriate approach for each **risk based** on the assessment results. The available approaches are risk **avoidance**, **mitigation**, **transfer**, and **acceptance**. Document the reasons for the decision and the authority responsible for approving it.

3.5 Risk Treatment Planning and Implementation

Develop a **risk treatment plan** for risks **requiring action**. The plan should identify the required actions, responsible party, target completion date, necessary resources, and criteria for verifying implementation.

3.6 Risk Monitoring and Review

Monitor the **implementation** of **treatment** plans and **verify** their **effectiveness**. **Review risk levels** and **controls** when changes, incidents, or new information occur.

3.7 Continuous Improvement

Use **monitoring** and **review results**, **incidents**, and **lessons learned to update risk assessments** and **improve treatment procedures** and the **methodology** when **necessary**.

4. Risk Assessment Methodology

The project adopts **Qualitative Risk Assessment**, using descriptive levels to estimate likelihood and impact and determine the overall risk level.

4.1 Likelihood Levels

- **Low:** The risk is **unlikely** to occur, and there are no strong indicators suggesting its occurrence.
- **Medium:** The risk is **possible**, and conditions exist that could allow it to occur.

- **High:** The risk is **likely** to occur due to vulnerabilities or conditions that increase its likelihood.
- **Very High: Strong indicators** suggest that the risk may occur soon or repeatedly, or current conditions make its occurrence very likely.

Likelihood assessments should be based on available information, such as previous incidents, vulnerabilities, and the effectiveness of existing controls. Where information is insufficient, the **information gap** must be **documented** and **considered** during the assessment.

4.2 Impact Levels

The impact of each risk is assessed against the system's three **objectives**: **Confidentiality, Integrity, and Availability**.

- **Low: Limited impact** on one of the system's objectives, without significant disruption to work.
- **Medium: Noticeable impact**, such as a limited error in patient information or temporary disruption affecting some tasks.
- **High: Major impact**, such as sensitive information being disclosed to an unauthorized person, the loss of important data, or disruption that significantly affects service delivery.
- **Critical: Very severe impact**, such as widespread exposure of patient information, loss of essential data, or a major system outage that severely affects business continuity.

The overall impact level is determined by the most severe material impact on the three system objectives. The rationale for the assessment must be documented.

4.3 Risk Levels

The following levels are used to classify the final risk assessment result:

- **Low**
- **Medium**
- **High**
- **Critical**

4.4 Risk Assessment Matrix

The **risk level** is determined by combining the **likelihood** and **impact** levels using the following matrix.

Likelihood / Impact	Low	Medium	High	Critical
Low	Low	Low	Medium	High
Medium	Low	Medium	High	High
High	Medium	High	High	Critical
Very High	Medium	High	Critical	Critical

This matrix provides a consistent basis for assessing and comparing risks. It does not replace the need to document the assessment rationale or consider the established risk appetite and tolerance.

5. Risk Appetite and Risk Tolerance

Risk assessment results must be compared against the risk appetite and risk tolerance documented in **03 - Risk Appetite and Risk Tolerance** within the Context folder.

The project applies a **very low risk appetite** to risks affecting information **confidentiality** and **integrity**, and a **low risk appetite** to risks affecting system **availability**.

The risk level alone is not sufficient to determine whether a risk should be accepted or rejected. Decisions must follow the approved criteria and defined authority, with the rationale for acceptance, treatment, or escalation documented.

6. Risk Treatment Options

The following options are used to address risks:

- **Risk Avoidance: Stop** or **change** an activity to avoid the risk.
- **Risk Mitigation:** Implement **measures** that reduce the **likelihood** of the **risk** occurring or **reduce** its **impact**.
- **Risk Transfer: Transfer** part of the **responsibility** or **financial impact** of the **risk** to **another party** through an **appropriate agreement**, **without assuming** that the **hospital's responsibility** for the system is automatically **eliminated**.

- **Risk Acceptance:** Make a **documented decision** to **accept** a risk by an authorized party, within the established limits and criteria.

7. Responsibilities

- **Hospital Management:** Provide **overall oversight** of risk management and approve treatment and risk acceptance decisions within its authority.
- **System Administrator:** Provide **technical information**, contribute to **risk identification**, **implement** approved **technical actions**, and **monitor** relevant **technical matters.**
- **Doctors and Registration Staff: Report risks and issues** related to their use of the system within their **respective duties**.
- **Cloud Service Provider: Provide** relevant **information** about **cloud services** and **address matters falling** within its **responsibilities** under the **service agreement**.

These responsibilities must be applied consistently with the approved governance documents, defined authority, and service agreement.

8. Continuous Risk Monitoring and Review

Risks must be reviewed according to a documented **review schedule**, and whenever an **incident occurs**, a new threat emerges, a significant change is made to the system, access permissions, or service provider, or new information becomes available that may affect the assessment.

The **review** must **verify** the **implementation** status and effectiveness of **treatment plans**, **update** risk levels when necessary, and determine whether additional actions are required.

Review outcomes, decisions, supporting evidence, and changes must be documented and used to support continuous improvement.

9. Documentation

Risk management **results** must be **documented** in the relevant project documents and records. This includes risk information, causes, assessments, treatment decisions, implementation plans, and monitoring and review results.

The **Risk Register** is used to consolidate information about each risk and track its status throughout the risk management stages, while maintaining consistency between the register and the approved documentation.